LLM-OWASP-MCP-AUTONOMY

OWASP LLM2025·프롬프트 주입·MCP·자율성 통제

연관 기출 · 138-1-12, 136-2-3, 136-4-5, 137-2-3, 140-2-6, 133-3-2

한눈에 이해

모델이 읽은 외부 문장을 명령으로 오해하더라도 실제 도구가 권한 밖의 일을 못 하도록 시스템에 서 경계를 둡니다.

정의와 핵심 원리

LLM 보안은 모델·데이터·검색·프롬프트·출력·도구·실행 권한을 포함하는 응용 전체 보안입니다. 프롬프트 인젝션은 신뢰하지 않는 입력이 모델의 의도된 정책·작업을 변경하도록 유도하는 취약점이며 직접 입력과 검색 문서 등 간접 경로를 구분합니다.

• OWASP 2025의 10개 항목은 프롬프트 주입, 민감 정보 노출, 공급망, 데이터·모델 오염, 부적절한 출력 처리, 과도한 에이전시, 시스템 프롬프트 유출, 벡터·임베딩 취약점, 허위 정보, 무제한 소비입니다. 해당 판본에서 항목 번호를 확인하고 위험이 생기는 곳과 영향, 대응을 연결합니다.

• MCP는 모델이 도구·자원과 연결되도록 돕는 프로토콜입니다. 도구 설명과 응답을 신뢰할 수 있는지, OAuth 동의와 토큰 수신 대상(audience)을 검증하는지 살핍니다. 권한을 대신 행사하는 중개자 악용, 토큰 전달, SSRF, 로컬 서버 실행도 검토합니다. 허용 서버 목록, 서명·검토, 최소 권한 범위, 자원별 인가, 비밀 격리와 감사를 적용합니다.

• 고성능 AI는 피싱·정찰·코드 생성 등을 더 빠르고 크게 수행하는 데 악용될 수 있습니다. 접근과 오용 탐지, 위험한 기능 평가가 필요합니다. 자율 실행의 위험에는 잘못 이해한 목표, 과도한 권한, 행동의 연쇄와 예산 초과가 있습니다. 읽기·쓰기 권한을 나누고, 허용 도구와 승인 기준, 실행 격리, 지출·시간 한도, 중단·복구 절차를 정합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
모델 수준	정렬·강건성 평가	정책 이탈 가능성 잔존
응용 수준	출력 검증·권한·실행 격리	비밀·SQL·도구 경계
운영 수준	감시·승인·중단·복구	자율성·규모·사고 대응

적용 예제

검색 문서의 악성 지시

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 검색한 문서 본문에 비밀을 외부로 보내라는 문장이 들어 있습니다.

1. 문서 본문은 처리할 데이터입니다. 본문에 든 지시로 권한이 바뀌지 않게 합니다.

2. 도구 서버가 사용자와 자원의 권한을 직접 검증합니다.

3. 외부 전송·삭제·배포를 요청하면 대상과 내용, 승인 여부를 확인합니다.

4. 실행 로그·예산·중단 조건과 사고회수를 갖춥니다.

결과·해석: 필터 한 겹보다 신뢰 경계와 최소 권한으로 실제 피해를 제한합니다.

전제·주의: 프롬프트 필터·정렬만으로 주입 완전 차단을 보장하지 않습니다. MCP는 열람 시 확인한 2026-07-28 보안 문서에 근거합니다.

답안 골격과 혼동 방지

LLM 전체 구조 → 2025 Top 10 → MCP 공격·대응 → 공격 지원·자율성 → 권한 경계 예

- 시스템 프롬프트를 절대 비밀 저장소로 쓰지 않습니다.
- 모델이 안전하다고 응답한 것을 인가 판정으로 쓰지 않습니다.

내용을 가리고 회상

1. 간접 프롬프트 주입은 어떤 경로로 들어올 수 있습니까?

2. MCP에서 토큰을 아무 서비스에나 전달하면 왜 위험합니까?

3. 어떤 행위에 자동 실행 한도나 사람의 승인이 필요합니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- 2025 Top10 Risk and Mitigations for LLMs and GenAI Apps - OWASP GenAI Security Project; 2025 목록; 확인 2026-11-05.
- MCP Security Best Practices - Model Context Protocol project; 2026-07-28 경로; 확인 2026-11-05.
- NIST AI100-2e2025: Adversarial Machine Learning - Apostol Vassilev et al. / NIST; 2025-03; 확인 2026-11-05.